

Parecer Tecnico do App TCS

Base: analise estatica do repositorio local em 10/04/2026.

Escopo: avaliacao tecnica com foco em seguranca, consistencia operacional e prontidao para uso institucional.

Achados Criticos

- A autorizacao por rota esta fraca no cliente. O painel expoe telas privilegiadas sem guarda de papel em `app/(panel)/_layout.tsx:45`. Em `app/(panel)/admin/usuarios.tsx:69`, qualquer usuario que nao seja `master_admin` cai numa consulta por municipio, e a propria tela tenta aprovar ou bloquear usuarios em `app/(panel)/admin/usuarios.tsx:102`.
- O fluxo de cadastro nao e transacional. A conta e criada no Supabase Auth antes da insercao em `public.users`, em `app/(auth)/register.tsx:316` e `app/(auth)/register.tsx:340`. Se a segunda etapa falhar, sobra usuario orfao no Auth e o e-mail fica marcado como ja cadastrado.
- O token de convite pode continuar reutilizavel apos um cadastro bem-sucedido. O consumo do token e chamado em `app/(auth)/register.tsx:359`, mas o retorno da RPC nao e validado antes do sucesso final.
- As fotos de vistoria estao sendo tratadas como publicas. `services/StorageService.ts:60` e `services/StorageService.ts:104` usam `getPublicUrl` para imagens, enquanto o PDF usa signed URL em `services/StorageService.ts:139`. Para um app de Defesa Civil, isso representa risco serio de exposicao de evidencia.

Achados Relevantes

- O sync de agendamentos pode ficar preso indefinidamente. `services/SyncService.ts:123` retorna cedo quando nao ha vistorias pendentes, e o sync de agendamentos so acontece depois em `services/SyncService.ts:213`.
- A politica de senha e inconsistente. O reset normal exige 8 caracteres com letras e numeros em `app/(auth)/reset-password.tsx:35`, mas o reset administrativo aceita qualquer senha com 6 caracteres em `app/(panel)/admin/usuarios.tsx:135`.

Verificacao

- `npm test -- --runInBand` não fechou com sinal de confiança. O Jest está com `testMatch` amplo em `package.json:78` e acabou varrendo cópias em `.claude/worktrees`.
- `npx tsc --noEmit` falhou porque o runtime compara status com `deletado` em `services/SyncService.ts:354`, mas o tipo em `types/agendamento.ts:14` só aceita `pendente`, `concluido` ou `cancelado`.
- No versionamento local, encontrei RLS explícita para `agendamentos` em `supabase/migrations/20260403_agendamentos.sql:20`, mas não localizei políticas versionadas para `users`, `municipios` ou `invite_tokens`.

Conclusão

A base do app é boa para um MVP operacional: stack coerente, modo offline com SQLite, sincronização em background, geração de PDF e trilha de auditoria. O ponto fraco hoje não está na proposta técnica, e sim no endurecimento de segurança e consistência.

Do jeito atual, a recomendação técnica é não colocar o sistema em uso institucional pleno sem corrigir RBAC por rota e por ação, tornar cadastro e consumo de token atômicos e revisar a estratégia de armazenamento das evidências fotográficas.

Documento gerado a partir da análise do repositório local `app_defesa_civil_expo`.